

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
Feb 2025	All	All	Wolfgang Stengel	Small updated to process / testing requirements throughout the document
Feb 2025	BACKUP	Risk Assessment	Wolfgang Stengel	Retained old information for risk assessment (part of fraud scenarios previously)
Feb 2025	Control Assessment Questions	Multiple	Wolfgang Stengel	Updated control assessment questions to reflect changes to Initial Data Requests
Feb 2025	Process and Objective	Fraud Template	Wolfgang Stengel	Newly added examples for fraud scenarios
Feb 2025	Process and Objective	Reference Material	Wolfgang Stengel	Updated links
Feb 2025	Control Assessment Questions	Labor Claiming	Wolfgang Stengel	New section for Labor Claiming
Feb 2025	Control Assessment Questions	Contract requirements	Wolfgang Stengel	Added delivery items from BPO to BPO-D
Feb 2025	Control Assessment Questions	Multiple	Wolfgang Stengel	Re-align control points across Control Assessment Questions
Feb 2025	Process and Objective	Audit Program Risk Alignment	Wolfgang Stengel	Multiple updates to Risk Area Evaluations (RAEs)
April 2023	Data Protection & Data Privacy	DP001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	6
PLANNING: Data Analysis.....	7
PLANNING: Reference Material	8
PLANNING: Fraud Template.....	9
CONTROL ASSESSMENT QUESTIONS	10
Key Control Question: 1. Delivery Management	10
Primary Test: Contract Requirements (SD001.P).....	11
Primary Test: Contract Performance Measurements (SD002.P)	13
Primary Test: Separation of Duties Analysis (SD003.P).....	15
Primary Test: System, Application, and Data Access (SD004.P)	17
Primary Test: Resource Management (SD005.P).....	19
Primary Test: Matrix of Responsibilities (MoR) (SD006.P).....	20
Primary Test: Export Regulation Office (SD007.P)	22
Primary Test: Disaster Recovery and Business Continuity (SD008.P)	23
Key Control Question: 2. Data Security and Privacy	26
Primary Test: Data Protection and Data Privacy (DS001.P)	27
Key Control Question: 3. Financial Management	29
Primary Test: Financial Controls (FM001.P).....	30
Key Control Question: 4. Labor Claiming	31
Primary Test: CLAIM (Common Labor Information Management) (LC001.P)	32
Key Control Question: 5. Asset Management.....	33
Primary Test: IBM Owned Assets and Software (AM001.P)	34
Primary Test: Customer Owned Assets and Software (AM002.P)	35
BACKUP – Historical risk definition	36

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

PROCESS AND OBJECTIVE

IBM performs business processes services for external customers in the areas Talent & Engagement, Finance and Accounting, Supply Chain Management, and Recruiting (RPO). The Business Process Operations-Delivery (BPO-D) organization within Business Process Operations (BPO) handles delivery execution, while BPO handles customer relationship management for these services contracts with external customers. The following description applies to the delivery process executed by BPO-D.

The extent of business process services delivered to client is determined by the requirements agreed to in the contract signed between BPO and the client. For some contracts, the customer will dictate not only the business process services to be performed, but also every aspect that is required to deliver the business process service. In other contracts, the customer allows IBM to execute the steps required to successfully deliver the business process services, without detailed specification. There can be wide variability in customer requirements and BPO-D endeavors to meet all requirements efficiently and consistently.

The process begins with the formal transition of a contract from BPO to BPO-D. At this time, the delivery center will validate receipt of deliverables from BPO, including process instructions, control points, scopes of work (SOWs), contract performance measurements, separation of duties matrices (SODs), documents of understanding (DOUs)/ Matrix of Responsibilities (MoR), and inter-company agreements (ICAs).

Resources and employee training are also a transition requirement. Transition ends with a formal sign-off by the delivery project executive (DPE) followed by the delivery center manager. At this point, BPO-D takes responsibility for delivery of services in compliance with contract requirements, until such time that the contract terminates. BPO-D also manages contracts to remain compliant with IBM requirements in such areas as access management, asset management, records retention, and labor claiming.

The process(es) continues to be executed as designed until such time as a change is requested by the delivery center or the client. All changes are reviewed by the project executive / delivery project executive and the delivery center manager. After all required approvals are received, an ICA is raised, DOUs/MoRs are updated (if necessary), and the center may begin to implement the change. Quarterly management self-assessment is performed, and a rating is assigned to the country process, taking into account compliance testing, recommendations from audit lessons learned, and any other sources of information across all center contracts. Any issues arising from the quarterly assessment are documented and tracked to closure.

Upon termination, BPO-D will be responsible for delivering to the termination requirements set forth in the contract.

Updates to the contract to accurately reflect both client requirements and delivery services are the responsibility of BPO.

This audit program will include the basic objectives and approaches when auditing business process services performed by IBM on behalf of external customers. Also included will be specific risks, fraud indicators, and approaches for business process service delivery in the aforementioned areas. As the delivery of each business process service is dictated by customer requirements in the contract, please keep in mind that the information identified under each type of business process service is a guideline and is not considered completely comprehensive.

BPO-D is tasked with establishing highly efficient, world class delivery capabilities in IBM's business process delivery operations and is focused on the **delivery** aspect of the solution design and the execution of the delivery portion of the customer relationship management (CRM) for services process.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

PROCESS AND OBJECTIVE (Continued)

BPO handles CRM for business process services contracts with external customers. When auditing BPO contracts, refer to the process for CRM for Services (audit program 60-00-00), which includes solution design and delivery and opportunity management.

- Solution design and delivery enables the design and delivery of a solution according to a customer's conditions of satisfaction, business needs, and required quality standards.
- After integrating all solution components, such as: quality assurance, credit, and pricing, a proposal is presented to the customer.
- Once the proposal is accepted, the solution delivery phase starts with a review of IBM commitments.
- The solution is then implemented. In parallel, it is managed to ensure a quality delivery of IBM commitments in a profitable manner, while ensuring customer satisfaction.
- Renewal or additional opportunities are also identified.
- The solution design and delivery portion of the CRM for Services process defines required activities to drive qualified opportunities to contract, plus the work required to assure correct delivery.

The auditor should ensure that services provided to the client are delivered in accordance with customer requirements and local regulations.

Scope Considerations

Centers performing for external customers

- Scope considerations: evaluate financial, operational, and strategic risks
- Contract requirements including contract performance measurements
- Access to applications and customer data, data privacy
- Laws and regulations applicable to the business processes being performed
- Business management system
- Management oversight and approvals
- Financial management involving customer funds or transactions
- Measurements and metrics
- Documents of understanding with other IBM organizations
- Separation of duties
- Staffing and training
- Disaster recovery plans
- Understanding the boundaries between IBM's responsibilities and the customer's responsibilities

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

PROCESS AND OBJECTIVE (Continued)

Services provided for external customers could include, but are not limited to the following business processes:

- Human Resources (HR):
 - Payroll
 - Travel
 - Travel Expenses
 - Pension
 - Benefits and Compensation
 - Learning and Recruiting
 - Relocation and Mobility
 - Workforce Management
 - HR Contact Center
- Balance Sheet Accounting
- Procurement
- Finance and Accounting: **Important:** Most of these tasks are delivered by BPO-D but not in all locations. It just depends on the contract agreement.
- Account Reconciliations

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

PLANNING: Audit Program Risk Alignment

Service Delivery External – BPO-D

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Delivery Management	High	Solution Delivery	SD001.P, SD002.P, SD003.P, SD004.P, SD006.P, SD007.P, SD008.P
Data Security and Privacy	High	Service Solution Delivery	DS001.P
Financial Management	High	Financial Management	FM001.P
Resource Management	High	Solution Delivery	SD005.P
Labor Claiming	Medium	Labor Claiming	LC001.P
Asset Management	Medium	Asset Management	AM001.P, AM002.P

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Most of the information obtained by audit for the purpose of universe review and sample selection is extracted from the external customer's applications.

Below is a list of items that can be obtained from the Technology team as they are specifically linked to the IBM ledger or IBM employees and contractors that are supporting the external customer's contract.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Delivery Center Costs	Obtain a list of costs reported in the ledger for delivery. Verify if costs included in measurement reports matched with those billed to the client.	Understatement or overstatement of costs; generic cost centers or codes	Costs are not being appropriately applied to the contract, projects, or other business units.
IBM Labor Claiming	Obtain a list of employees and contractors who claimed hours in the Intranet Labor Claiming Tool (ILC) for the projects and contracts associated with the services being provided.	Duplicate hour claiming; claiming hours on multiple contracts; hours claimed while on vacation; hours claimed for nonexistent or separated employees	Inaccurate and unauthorized hours charged to the external customer for the work being performed which could lead to customer dissatisfaction and legal issues.
Access to IBM applications and databases	Obtain a list of all employees who left the company during the audit period, including accesses granted and access removal details.	Inappropriate accesses; access after separation or job change; inadequate level of access	Ineffective access control process could affect customer satisfaction, expose confidential information, lead to possible contract termination, and result in financial loss.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

PLANNING: Reference Material

Please see the sections below for a listing of applicable Corporate Instructions, Policy Memos, and Procedures Manuals.

Corporate Instructions

Disaster Recovery: <https://w3.ibm.com/ibm/corporate-documents/cio/cio-127>

Processing of Business Personal Information: <https://w3.ibm.com/ibm/corporate-documents/mcc/mkt-115>

Control of Disbursements: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>

Export Regulations: <https://w3.ibm.com/w3publisher/ibm-export-regulation-office/us-export-regulations-program-userp>

FIN 182 Appendix C - Separation of Duties: <https://w3.ibm.com/w3publisher/financebc/ibm-framework/ci-fin-182-appendix-c>

Policy Memos

Business Conduct and Ethics: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-103>

IBM Data Privacy Policy: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>

Technology and security standards: <https://pages.github.ibm.com/ciso-psg/main/>

Quality: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-140>

Accounting Practices and Instructions

Link to Accounting Practices, Instructions, and Interpretations:

<https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting/accounting-practices-interpretations>

Superseded Accounting Practices Archive:

<https://ibm.ent.box.com/s/9h1v8bbq8kjjucmzv5tky7fbsx7sslu>

General Data Protection Regulation (GDPR)

GDPR Readiness Community: <https://w3.ibm.com/ibm/privacy/gdpr>

Compliance Programs: <https://w3.ibm.com/ibm/privacy/programs>

Other Useful Links

Link to BPO Homepage: <https://www.ibm.com/services/outsourcing>

North America and Europe Publisher: <https://w3.ibm.com/w3publisher/cps-na-publisher>

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Application Access/Separation of Duties (SOD): The use of applications and databases, specifically those containing personal or sensitive data, as a result of unapproved or unnecessary system access.	Continued Business Need (CBN) reviews are performed for most applications. System access levels associated to roles to maintain SOD.	Review system access lists including the CBNs performed on the applications. Perform tests to validate some of the transactions performed. Establish if accesses are in line with job roles, and that individuals do not have accesses to multiple ids to circumvent SOD controls.
Financial Recording - Improper cost recording in order to meet GP targets, e.g., (i) unsubstantiated accruals or (ii) cost deferred without review and approvals.	Accounting reviews. Management reviews. Compliance testing KCFRs.	Review accruals and cost deferrals. Ensure that information sent to Accounting for review is accurate and enables Accounting to make a fully informed judgement.
Theft of assets (such as PCs, servers, or software) as a result of the absence of or insufficient asset reconciliations.	Book to floor (B2F) and floor to book (F2B) reconciliations. Movement between locations tracking.	For contracts where IBM own assets or is responsible for the tracking of customer assets, review the asset reconciliations. Select sample of assets and perform reconciliations during the review.
Resource Management	On-boarding process	Sample on-boarding for repeated official document numbers to indicate an invalid employee is being paid. Use Data Analytics to evaluate unusual patterns.
Procurement – Kickback, Preferential treatments	Supplier Selection process, Fair value process	Sample subcontractor POs for procurement involvement. Review payment verification process. Review IOI's where applicable.
Procurement – Bypass	Bypass tracking and Review of disbursements	Verify payment made without PO's and payments made on the date the PO was issued.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Objective:

Are business process services delivered to external customers in accordance with contractual obligations? Are there adequate measurements and monitoring programs in place to ensure that IBM is delivering business process services as specified by the customer? Are internal and external resources monitored and utilized effectively? Is revenue recognition (if applicable) and cost allocations in accordance with accounting instructions? Are there comprehensive controls in place to safeguard both the customer's data and the customer's assets?

Risk/Exposure:

Because of the complexity of most BPO solution delivery projects, the execution phase requires a particular focus on IBM performance, versus contract commitments and customer expectations. The lack of project follow-up and of monitoring for subcontracted services, and failure to effectively use or reallocate resources could jeopardize IBM's ability to fulfill the contractual commitments and result in cost overruns, negatively impacting profit. Misuse of the customer's financial resources could lead to adverse legal and financial implications for IBM. Specific risk / exposure by service include:

Procurement

- Failure to properly control the selection of suppliers could create excess expenditures, affect supplier relations, and lead to fraud.
- Failure of suppliers to meet established performance targets decreases IBM's ability to provide high-quality, low-cost products and services.
- The absence of a good internal measurement and controls system creates the environment for fraud to occur and could lead to excessive expenditures.

Human Resources

- Insufficient understanding of a customer's recruitment process could lead to inaccurate employee records, which could result in legal exposure.
- Non-adherence to data privacy laws could result in legal exposure.

Finance and Accounting

- Inaccurate financial reporting to customers could lead to financial misstatements and noncompliance with laws and regulations.
- Ineffective management system could damage IBM's image.

Insurance

- Untimely resolution of insurance claims could result in customer financial loss and dissatisfaction.
- Failure to obtain proper approvals for insurance payments could result in unauthorized payments/loss of funds.

CRM (Call Center)

- Slow response time to answer calls could result in financial penalties and customer dissatisfaction.
- Lack of proper measurements to track the effectiveness of incoming calls could lead to customer satisfaction issues.

Notes:

For the Procurement process: keep in mind that IBM, specifically BPO-D, is making commitments on the customer's behalf.

For all other processes described above: keep in mind that IBM, specifically BPO-D, is gathering, maintaining, using, and perhaps reporting sensitive financial information on the customer's behalf.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Requirements (SD001.P)

Objective:

This topic specifically addresses business process services being delivered to external customers.

Ensure that adequate, effective, and timely contract change management controls were in place for changes to the delivery of business process services requested by the customer, and how accurately they were included/updated. This should include service requests, in-scope and out-of-scope contract changes, and terms and conditions changes. Although contract change management is BPO's responsibility, there could be implications for business service delivery.

Operational Framework: A statement of roles and responsibilities with regard to the delivery of contracted services on a BPO outsourced Client agreement, it is a binding document between the DPE and the PE to ensure that the expectations and responsibilities of each role is well defined and agreed upon.

Matrix Of Responsibilities (MoR): It is a binding document between the DPE and the delivery center, which is clarifying each contract scope of work and contract performance measurements performed by each delivery center in support of the customer agreement.

Approach:

For the sample selected from the universe, test against the following criteria:

1. Did the current SOD reflect the current processes including the tasks, roles, applications and system, which are reflecting the agreed upon SOW with the customer?
2. Did the contract contain an audit clause? If the audit clause has been exercised, were the results reviewed and were appropriate action plans implemented?
3. Did the contract contain customer specific controls to be performed by IBM?
4. Did the contract include exclusivity clauses for employee support?
5. Were the contract and any subsequent requests to BPO-D valid? Were contract changes properly approved and communicated prior to implementation?
6. Were BPO-D performance measurements and deliverables, if applicable, for both IBM and the customer specified in the MoR?
7. Were change controls in place to identify updates to the scope of work? Were they accurately mapped in the MoR? Were changes to contracts approved and documented prior to the effective date of change? Were exceptions identified and business justification documented?
8. Did the scope of work adequately identify business process services to be performed for the customer and end users?
9. Was there a process to properly track performance measurement and deliverable management in accordance with contract requirements?
10. Was there a process in place to review, monitor, and implement additional services requested by the customer? Ensure this process was part of IBM's methodology to deliver services to external customers.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Requirements (SD001.P)

(Continued)

Transitioning Contracts

1. Were the SOWs documented and approved prior to start of delivery?
2. Were the Contract Performance measurement documented and approved, including targets, prior to start of delivery or in accordance with the contract requirements.
3. Were all delivery issues noted on the transition issues log closed or transferred to the Delivery Issues Log prior to start of delivery?
4. Were the delivery Process Documentation (Process Narratives, Control Points, Flow Charts, and SODs) in place prior to the start of delivery?
5. If applicable, were the DOUs/Matrix of responsibilities and ICAs written/updated and approved by all required parties prior to the start of delivery?

Terminated Contracts

1. Were contract terminations performed in accordance with the terms and conditions of the contract or initiated based on an approved addendum/work scope change?

Validate receipts of delivery items from BPO

1. Process instructions,
2. Control points,
3. Scope of work,
4. Contract performance measurements,
5. Separation of duties,
6. Document of understanding,
7. Matrix of responsibilities,
8. Intercompany Agreements,
9. Resource and employee training and
10. Transition requirements.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Performance Measurements (SD002.P)

Objective:

This topic specifically addresses business process services being delivered to external customers.

To ensure conditions of success, as specified in the contract with the customer, were met. This was done through the attainment of contract performance measurements specific to the delivery of business process services. Failure to meet these measurements could lead to penalties to IBM, customer dissatisfaction, and possible breach of contract.

Approach:

Identify all contractual commitments classified as contract performance measurements from the contract. These are measurable and generally reportable commitments that are made to the customer for services to be provided. These contract performance measurements will be measured against the commitments included in the MoRs. The inability to attain these measurements, could result in penalties to IBM or contracts cancelled by the customer. The measurements covered by this document are those specifically tied to the business process services being delivered to the external customer.

1. From a sample of contract performance measurements with monetary and non-monetary repercussions, review the following:
 - a. Were the results of contract performance measurements reported to the BPO organization timely as identified in the MoRs?
 - b. Were the results of contract performance measurements reported to management periodically to ensure proper oversight?
 - c. Were the results of contract performance measurements accurately reported as agreed to in the MoR?
 - d. Was root cause analysis completed for contract performance measurements that did not meet the attainments specified in the MoR?
 - e. If the contract performance measurements were tied to a breach of contract clause, was there proper oversight over the contract performance measurements not being met to mitigate exposure of recurrence and possible breach of contract?
 - f. For contract performance measurements that were contractually required, but not reported to BPO, was BPO recognizing the difference and managed it outside of BPO-D?
2. Were coherent action plans created? Were these action plans assigned to an owner and with due date for execution? Was the status of the action plans updated? Where they reported timely to the customer, if required?
3. Were any misses to the contract performance measurements communicated to the concerned parties in a timely manner?

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Performance Measurements (SD002.P)

(Continued)

4. Was there an issues Log in place, which is properly documenting and tracking all issues that might interrupt operations or any misses in our contract performance measurements?
 - a. Did each issue has action plan, owner, estimated date of closure, and severity level was assigned to each issue on the issues log?
 - b. Were Due date changes tracked in the issues log? log included both the original due date and the new due date? and there was evidence that due date changes were communicated to concerned parties (if applicable) before the official target date expires and documented evidence of concurrence is on file?
5. If applicable, request customer survey results (external / internal) during the audit period. Review process of monitoring and closure of service delivery-related issues from customer feedback surveys.
6. Review the governance model or management system in place to check, report, or monitor contract performance or any internal measurements, if applicable.

Risk and Issue Log (RAIL)

1. Was the RAIL maintained and reviewed by the responsible delivery manager or the official delegate on a monthly basis?

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Separation of Duties Analysis (SD003.P)

Objective:

Ensure that a separation of duties assessment is performed and approved by the process owner or delegate annually, or more frequently as necessary. Validate that identified separation of duties conflicts are eliminated, mitigated, or accepted based on risk severity. Ensure that conflicting tasks which should be separated, but are not, have effective secondary controls in place. Analysis of Separation of Duties (SOD) should adhere to the guidelines set forth in Corporate Instruction FIN 182 - Management Self-Assessment of Control Appendix C - Separation of Duties.

Requirements:

Global and country process owners are responsible for maintaining adequate separation of duties within their processes:

- The end-to-end process must be reviewed at least annually to identify the tasks which, when combined, could result in a loss or misuse of IBM or customer assets (including data); or allow fraud to be perpetrated. The analysis should be done at the appropriate level (global, country, or other level) taking into account country variations or other factors which impact the SOD assessment.
- SOD assessments should be kept current and should be updated when organization, staffing assignments, process or system changes occur which are significant enough to impact the current SOD assessment.
- The approach to separating duties, whether by process design, system controls, organizational structure, or other means should be established and maintained on an on-going basis.
- Identified conflicts should be assessed for SOD risk and a determination should be made as to which conflicting tasks should be separated. Conflicts may be eliminated, mitigated, or accepted based on risk severity.
- As a result of the SOD risk assessment, any conflicting tasks identified which should be separated but are not, need to have effective secondary controls in place to mitigate the risk.
- The completed process SOD assessment and documentation must be approved by the process owner or appropriate delegate.

Approach:

1. Review and test, as necessary, the SOD assessment to validate that a complete SOD, including all system accesses, were performed, up to date, reviewed, and approved by management. Verify that potential conflicts were identified, and secondary controls established.
2. Review if the end-to-end process was reviewed at least annually and at the appropriate level and the results were documented and approved by the process owner or delegate.
3. Review if identified conflicts were assessed for a determination and if supporting documentation was available to validate the assessment.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Separation of Duties Analysis (SD003.P)

(Continued)

4. Review if secondary controls were needed. Were they identified and would they mitigate the conflict effectively?
5. Review if financial processes were included in the end-to-end, if applicable. Were KCFRs, KCOs or IKCs defined and implemented? If applicable, were they tested timely and properly with documented results?
6. Review if applications and systems were listed in the SOD and related accesses were assessed.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: System, Application, and Data Access (SD004.P)

Objective:

To ensure that access to systems used to deliver business process operations services to external customers are controlled in a timely manner, and to prevent unauthorized access to applications and information used to deliver business process operations services to external customers. Appropriate management approvals should be granted and documented according to business need. Ensure adherence to Information Technology Security Standards, Computer Security and Use Guidelines.

Password Sharing

To ensure that management approvals are in place before any password sharing takes place and that the process in place should include predefined controls.

- Verify that a process is in place to safeguard data, which is reviewed or stored as part of delivering business process services to external customers.
- Verify accountability for shared userids can be established or effective secondary controls are in place.
- Verify if a process has been implemented to timely revoke accesses no longer required.

Approach:

1. Review and identify a list of key applications and databases used to deliver business process services to external customers.
2. Review contract clauses related to data protection and accesses granted to IBM employees.
3. Review the processes surrounding access controls for the key applications supporting the audited process. In particular, review access to customer data. Include both IBM and customer systems, applications, and data in scope when appropriate.
4. Review compliance with ASCA and applicable certifications in place for spreadsheets owned by BPO-D and used as trusted information sources.
5. Review if an annual process was established to timely revoke accesses no longer required.
6. Review if procedures for maintaining an access / activity log of individual accountability for usage of shared userids (if applicable).
7. Review if password control procedures are in place for shared userids (check-in/check-out).
8. Review if there are procedures for the removal of access and password resets.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: System, Application, and Data Access (SD004.P)

(Continued)

Access Control

1. Obtain a list of applications used and review the process for granting access approvals to ensure that business need/justification was confirmed. Ensure access was approved by appropriate approvers. Review the process for periodic verification of employees and validation of continued business need inline with contractual requirements as documented in the MoR and IBM's Corporate Instructions. In addition, ensure that access for leavers (including internal transfers) was deleted in accordance with timeliness requirements in IT Security Standards or contracts.
2. From the access lists provided in the universe, was there a periodic business need revision performed by management inline with contractual requirements as documented in the MoR and IBM's Corporate Instructions?
3. Were system controls and execution in accordance with the contract signed with the customer?

Note: If the delivery center is the party responsible for actual deletion, then testing should cover actual deletion and not the request to delete access.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Resource Management (SD005.P)

Objective:

To determine whether appropriate resources were recruited and trained to perform services to fulfill client needs. Ensure proper agreements were in place when the use of subcontractors or vendors was committed. Additionally, measure employee, subcontractor, and vendor hours claimed to determine if they were consistent with actual hours serviced to the client.

Approach:

Workforce Management

1. Were resources in place to perform services for an external customer as contractually agreed?
2. If use of subcontractors or vendors was required to deliver the service, were customer requirements followed?

Education and Recruitment

1. Review training and education processes for new and existing employees, subcontractors, and vendors. Were there sufficient resources to execute contractual obligations? Were the skills of the workforce adequate for all job tasks defined in the contract?
2. Review contract to identify requirements for On-/ Offshore Resourcing. If a requirement exists, were reviews, controls, and oversight in place to ensure IBM can meet contract commitments?

Vendors

1. Were contract specific requirements related to vendors/subcontractors communicated to Procurement in a timely manner?
2. Was there a purchase order (PO) created before hiring a subcontractor? Was the PO valid for the duration of subcontractor employment?
3. Was there a periodic control of subcontractor or vendor labor hours completed executed? Did this control assure that subcontractor or vendor services started after purchase order approval?
4. Where customer required non-disclosure or confidential agreements, ensure that vendors were included under such, and had signed similar clauses with IBM Procurement.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Matrix of Responsibilities (MoR) (SD006.P)

Objective:

To ensure that the contract scope and related measurements are well defined, a Matrix Of Responsibilities was mandated, which is covering the contract scope of work, and contract performance measurements. This matrix should be signed by both the center management and the DPE of each account, at least annually or when changes occur, to ensure that expectations are well defined and to avoid work at risk. The MoR should give BPO-D DPE and the delivery center an opportunity to recheck and revalidate that all delivered services are explicitly in scope with the original contract between IBM BPO and the customer and that the performance measurements are also stated explicitly in the contract and properly reflected in the MoR.

This matrix should be signed by both the center management and the DPE of each account, at least annually

Risk/Exposure:

Management should use MoRs to manage roles and responsibilities among IBM organizations so that obligations to customers are met. Adverse results could include penalties and possible breach of contract for missed services.

MoR terms and conditions, including a definition of the scope of work as well as expected deliverables, must be clearly stated, or miscommunications and prolonged disputes between organizations could result and adversely impact the continuity of services.

Risks associated with unclear or undocumented MoRs include improper separation of duties, work begun on processes before MoRs are documented and approved, responsibilities that are not clearly defined, improper validation of measurements, unexplained errors, unclear or missing work scope, lack of required approvals, inadequate use of required resources, and significant changes to process relationships without a corresponding change to terms and conditions on MoRs.

Approach:

Review the process documentation developed that defined management responsibilities for meeting organizational business objectives.

1. Was MoR in place prior to commencement of services and were the proper approvals documented?
2. Was there an established process for reviewing, adjusting, and managing these agreements on a periodic basis?
3. Did the agreement clearly define the scope of work and contract performance measurements?
4. Were the requirements complete, and the deliverables defined and measurable?
5. Did the agreement define the data flow and control requirements (typically only applicable for 2+ locations) within the process for the specified service?
6. Were process deliverables clearly defined and were performance measurements/metrics specified?

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Matrix of Responsibilities (MoR) (SD006.P)

(Continued)

7. Had line management established a method for validating that services were being received or performed as agreed?
8. Have process measurements been established to identify deficiencies within the process? Were measurements reviewed, deviations from the target level analyzed, root causes established, and corrective actions defined and implemented?
9. Were there any changes in the process during the audit period? If so, were change control procedures established so that management could request changes and updates to the MoR?
10. Was there a process to track and monitor deliverables to assure realization of business objectives?

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Export Regulation Office (SD007.P)

Objective:

To validate if operations were adequately managed to verify compliance with the Export Regulation Office (ERO) United States Export Regulation Program (USERP) requirements, and corporate and local procedures governing export compliance requirements.

There are adequate on-boarding/transition processes in place to ensure any export control delivery restrictions have been identified and accounted for.

Risk/Exposure:

Failure to comply with IBM's export requirements could result in significant penalties and the potential loss of IBM's export privileges. Potential penalties include monetary fines, loss of market access, imprisonment, and debarment.

IBM's export requirements include among other requirements related to classification (of product, service, technology, and OCEs), compliance with license conditions or conditions of use for license exceptions, restricted party screening, anti-boycott compliance, and economic sanctions.

Approach:

Export Regulations - USERP Section 6 Part 1: <https://w3-01.ibm.com/chq/ero/ero.nsf/Pages/USERP-Section+6+Part+1>

(Please read the above export regulation requirements)

1. Was there a new contract or a contract modification including incremental scope including a delivery center resource?
2. Did the opportunity owner prepare the Client Services Evaluation Guide (CSEG):
 - a. Required questionnaire at project level.
 - b. Answers with yes require Export Regulation Coordinator (ERC) / ERO review and approval.
 - c. Did the ERC / ERO approval / guidance include any actions or screening controls to be implemented by receiving country delivery team?
 - d. Was the CSEG handed over to the receiving country delivery team prior go live? (No work to commence prior to a fully or conditional approved and executed CSEG)?
 - e. Had restrictions been identified that prevented the general use of global resources or that prevent the use of a specific global resource in delivery?
 - f. In case of required actions and controls as per ERC / ERO:
 - i. Did the receiving country delivery team document the process to implement the actions / controls and got it approved by ERC / ERO?
 - ii. Is there evidence to demonstrate implementation of the documented process?

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Disaster Recovery and Business Continuity (SD008.P)

Objective:

To determine if process owners have developed, reviewed, and tested client-requested business continuity plans (BCP) or disaster recovery plans (DRP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Were disaster recovery or business continuity commitments documented to ensure that services being provided on behalf of the customer were recoverable in case of disruption? Was there a disaster back-up and recovery plan for the computing and operating environments? Has the plan been agreed to by both parties? Has the plan been tested as required or at least annually? Did the plan identify and include all Global Resourcing locations?

Please note that the terminology, BCP is being used for simplicity. Depending on the customer or contract, either BCP or DRP will be used.

Risk/Exposure:

If IBM was unable to recover processing or operating capabilities following disruption due to accident, disaster, or other emergency, obligations to customers may not be met. This could expose the company to financial and legal ramifications and customer satisfaction issues. Many business processes have been centralized, and often operations are conducted in locations, which may be susceptible to business disruption. As a result, it is important that business and process owners have developed plans to maintain continuity of business operations.

Approach:

In the initial data request, seek information from the process owner if BCP or DRP is required by the client per the contract. If required, check if the requirements in the contract were adhered to. The following is a list of items to consider for review:

1. For contract samples selected, verify if business continuity plan (BCP) / services were contracted with the client.
2. Obtain copy of the BCP clause and understand the contractual obligations, if Contract is silent on BCP or commits to Site Hardening only then BCP is out of scope.
 - a. What were the scenarios to be covered by the business continuity services?
 - b. Did this could include suppliers and non-IBM locations?
 - c. Was there a defined time frame to resume operations (recovery time objective) in case of major disruptions?
3. Obtain copy of the approved BCP plan, verify evidence it's been approved by the designated approvers in the BC Plan and by when the plan was to be implemented.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Disaster Recovery and Business Continuity (SD008.P)

(Continued)

4. Review and evaluate the thoroughness of the BCP plan. Part of this evaluation should include an inquiry with the organization regarding what is needed to continue operations in the event of a business continuity disruption. Does the BC plan clearly identify dependencies such as site critical skills human resources (such as phone numbers and/or email addresses), IT, suppliers, partners, non-IT services”

Here are some potential items to review for inclusion in the BCP:

- a. If the process is executed at a primary location, were plans put in place for backup infrastructure if the infrastructure at the primary location is inaccessible? Items for backup infrastructure may include:
 - i. Space and power systems, if alternate site recovery
 - ii. Personal workstations and necessary software, and Network, if alternate site
 - iii. Servers
 - iv. Phones, or soft-phone capabilities
 - v. Are there other items that the auditor can identify?
 - vi. Home Internet enablement for BCP work from home
 - b. If applicable, did the process owner review or synchronize their BCP with the appropriate local site crisis management teams (CMT)?
 - c. Were there back-to-back agreements in place with potential suppliers of the backup infrastructure, to reduce the risk that this infrastructure might not be available in the event of a business disruption?
 - d. Review that BCP included an established communication plan for when BCP was initiated.
 - e. BCP call tree should be established such that when initiating a BCP, communication can flow from top level management all the way down throughout the account, delivery and IT teams (incl. suppliers).
 - f. Ensure recover activities are defined as well as predetermined time frames for resolution.
 - g. Verify whether BCP was reviewed and understood by individuals identified in the BC Plan as reviewers and approvers.
5. Verify that a BCP plan was implemented and tested at least annually or more frequently, if contractually required, and obtain test results.
- a. Were BCP implemented when required per contract?
 - b. Was the BCP regularly reviewed and monitored by the BCP designated reviewers and approvers (management) to meet the business requirements, scope, and objectives as per contractual requirements?

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Disaster Recovery and Business Continuity (SD008.P)

(Continued)

6. Verify the test results and that they were communicated to the client.
 - a. Review how the BCP was tested.
 - b. Were these results and responses being documented, reported, and included in the repository to determine and authorize actions for remediation and continual improvement?
 - c. Was a root cause analysis performed to document results when the test brought up unexpected results?
 - d. Was an action plan put in place to ensure the mitigation of deviations?
7. Verify actions taken to remediate issues identified during the BCP test.
8. Observe any issues identified, and remediation actions taken for actual BCP cases during the audit period.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Objective:

Evaluate whether data, including personal information (PI) and sensitive personal information (SPI) is appropriately secured and protected.

Risk/Exposure:

Failure to protect PI and SPI could enable fraudulent activity, which could result in dissatisfied employees, damage to employees and to IBM's image, and expose IBM to risk of litigation.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Protection and Data Privacy (DS001.P)

Objective:

Evaluate whether data, including personal information (PI) and sensitive personal information (SPI) is appropriately secured and protected.

Approach:

1. Understand if the contract with customer requires any control on themes related to data privacy and data security/protection.
2. Evaluate physical security of areas where information is handled, stored, or discarded. Include office and work areas, file rooms, copier rooms, areas where checks are processed, areas where confidential material is discarded, etc. Look for unsecured laptops (unsecured areas only), exposed hard copy material, etc. If controlled access system means are used, how frequently are these monitored.
3. Evaluate if PI and SPI is protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process.

Data Privacy

1. Review the customer's definition of data privacy and documentation requirements to protect customer and end user information. Were all data privacy requirements agreed in the contract, including requirements by law, fulfilled? (i.e., criminal background verification, etc.) Were there proper controls in place to ensure that customer's information was secured?
2. Review documentation to ensure proper classification of information. Was there a clear definition provided by the client of what information should be considered confidential?
3. File transfers among IBM and vendors, including encryption and classification as IBM Confidential.
4. Review spreadsheet protection.
5. Review contracts with vendors or contractor employees. How is data privacy assured? How does IBM monitor vendor protection of data?
6. If applicable, review if Data Protection Regulation and Compliance (DPRC) requirements were deployed, controls were in place, monitored and reported.

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Protection and Data Privacy (DS001.P)

(Continued)

- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link: <https://ibm.ent.box.com/file/1526853265612> .

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link: <https://ibm.ent.box.com/file/1526845316441> .

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

Workplace Security

1. Review common tests for anyone involved in performing process steps. This includes IBM employees, contractor employees working for IBM departments, and vendor firms (their employees).
2. Workplace security (controlled access, workspace, file rooms, print output rooms) with focus on areas that could represent exposures/breaches to the customer contract. Verify that customer requirements related to this topic were properly, promptly, and effectively implemented.
3. Verify any customer specific requirements related to workplace security for sampled contracts.
4. Verify if there are requirements to report deviations to the customer, if so, ensure they were reported accordingly.
5. Review if actions plans were implemented for offenders.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Objective:

To ensure costs of delivering business process services, including labor and other elements, were properly and accurately monitored, and reported, in accordance with IBM procedures, contract requirements and staffing plan.

Risk/Exposure:

Inadequate management review may result in financial issues going undetected, root cause analysis not being performed for missed, and timeliness of corrective actions not being taken, leading to potential financial misstatements for IBM.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Financial Controls (FM001.P)

Objective:

To ensure costs of delivering business process services, including labor and other elements, were properly and accurately monitored, and reported, in accordance with IBM procedures, contract requirements and staffing / cost case.

Approach:

Contract Costs

1. Review variances from the original cost case for the service delivered to the external customer, to determine the cause and validate that original assumptions were appropriate. In addition, ensure that changes to the cost case have had proper review and approvals.
2. Review project and financial schedules for service delivery to external customers to validate attainability and ensure that all factors and risks were considered. Aggressive project schedules could result in increased costs.
3. Verify that costs overseen by BPO-D and reported to the Project Executive (PE) were accurate, reviewed, and sent to the PE in a timely manner.

Financial Management

1. Obtain documentation for last year's recovery rates. Ensure supporting documentation, used to calculate the recovery rates such as IT, RESO, HC provisions, and amounts have proper supporting evidence.
2. Obtain a list of balance sheet accounts that may be impacted by the BPO-D activity.
3. Select a judgmental sample of balance sheet accounts to determine if recorded balance sheet positions were accurate and supported.
4. Review measurement packages to verify whether cost and balance sheet information for the service delivered was current, accurately reflected financial position, and had proper management oversight.

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Labor Claiming

Objective:

To ensure that labor claiming is recorded in a timely and accurate manner. To ensure that labor charges are assigned to the correct work items, rates and bands agree to employee records, and hours are validated against applicable time recording documents and internal interlock agreements. To ensure that there is no SOD conflict on the current process.

Risk/Exposure:

Inaccurate clocking of labor hours could result in significant over or under recovery of cost. In addition, incorrect assignment of labor charges to work items and inaccurate rates and band levels compared to employee records could result in financial misstatement.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Labor Claiming

Primary Test: CLAIM (Common Labor Information Management) (LC001.P)

Objective:

To ensure that labor claiming is recorded in a timely and accurate manner. To ensure that labor charges are assigned to the correct work items, rates and bands agree to employee records, and hours are validated against applicable time recording documents and internal interlock agreements. To ensure that there is no SOD conflict on the current process.

Approach:

As part of the process review request details on the management system governing time recording and labor claiming (including detail of specific codes usage and how this relates to work). In addition, ensure local labor laws and band level / employee type limitations regarding overtime are addressed.

1. Determine if there are written processes or local guidelines for CLAIM
2. Business should be using ILC (intranet labor claiming) tool as opposed to VM tool with some limited exceptions which need to be documented
3. Identify the CLAIM administrator(s) and obtain a schedule of the reports published, frequency, distribution list, measurements, review and correction process
4. Obtain a list of holidays, vacations, and leave of absences taken during the audit period for all employees.
5. Obtain a listing of the authority levels from the EMF (employee master file) records
6. Obtain a listing of authorized employees that can claim the hours on behalf of others
7. Determine if there is a revalidation process for users
8. Analyze retroactive adjustments of claimed hours, and the corresponding vendor payment adjustments, in the case of subcontractors

Attributes

1. Is work performed and are hours charged to work items prior to contract or SOW being signed?
2. Verify how Time and Material billable hours are controlled.
3. Review education hours and on-boarding training. Were those hours claimed appropriately?
4. Are labor claims linked to the correct project code and account ID, and are labor hours charged to an awaiting code transferred to appropriate charge code timely?
5. Are CLAIM hours verified against the non-exempt time records required for employees and contractors?
6. Are there appropriate intercompany agreements (ICA) in place and timely approved?
7. Are there appropriate ~~approvals~~ reviews for the number of hours clocked, incl. subcontractors?
8. Were overtime hours claimed accurately and in accordance with labor laws/regulations?
9. Review monthly labor hour reporting and investigate reversals of labor bookings.
10. Verify if hours claimed for others are reasonable and reviewed properly.
11. Are the retroactive hours/disbursements adjustments material to distort the utilization measurement, over / under calculation or lead to inaccurate vendor payments?

Exception Reports

1. Early CLAIM
2. Excessive overtime – set clip level
3. Time input by someone different than employee
4. Hours processed outside of the time period
5. Negative hours
6. Modifications to EMF records – rate, band, work item

SERVICE DELIVERY EXTERNAL – BPO-D AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Asset Management

Objective:

To determine whether controls in place were effective to ensure assets and software acquired, assets owned by IBM and utilized by the customer, and owned by the customer and utilized by IBM were in accordance with corporate requirements. Also, to verify if assets and software were properly verified, tracked, reported, and licensed according to IBM policies and procedures, as well as customer contractual agreements.

To ensure that access to IBM systems was controlled in a timely manner, and to prevent unauthorized access to IBM applications and information. Appropriate management approvals should be granted and documented according to business need. In addition, to ensure that access to customer systems was properly controlled.

Risk/Exposure:

Failure to control assets used to deliver services contractually agreed could impact the integrity of IBM's financial statements and negatively impact customer satisfaction. In addition, if complete reconciliations and physical verifications of all assets were either not performed, or cannot be demonstrated, this could result in loss of IBM and customer assets.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Asset Management

Primary Test: IBM Owned Assets and Software (AM001.P)

Objective:

To verify whether controls were effective to ensure that client or IBM owned assets, used in the service provisioning, were managed in accordance with IBM corporate requirements. Were IBM assets properly verified, tracked, reported, and licensed according to IBM policies and procedures, and contractual agreements?

Approach:

IBM Owned and Used Assets

1. Review the latest inventory to verify:
 - a. Confirm verification of assets against IBM's asset tracking system.
 - b. Missing assets were resolved or written-off in a timely manner.
 - c. Inventory results were reviewed by management on a timely basis.
2. Ensure that timely and accurate verification between local asset control files and IBM's asset tracking tools were performed.
3. Ensure assets were properly recorded in the IBM inventory tracking systems.
4. For leased assets, validate that the asset owner was correctly registered, that "installed-at" customer address number was accurately listed in the customer master record, and proper charging to the contract that in which the asset is being used.
5. Conduct a workplace security to verify if controls were properly established to ensure assets cannot be removed without detection. Specifically, view stockrooms for proper security measures, laptops, and locked facility cabinets or desks containing assets.

IBM Owned Software

1. Ensure that required consents were obtained for IBM licensed software in instances where the customer or customer's end user will be using the software.
2. Verify that there were controls in place to adequately monitor IBM software being utilized by a third party.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Asset Management

Primary Test: Customer Owned Assets and Software (AM002.P)

Objective:

To verify if controls were effective to ensure that assets acquired or owned by the customer and utilized by IBM, were in accordance with customer requirements. Were customer assets used by IBM properly verified, tracked, reported, and licensed according to policies and procedures, and customer contractual agreements?

Approach:

There are two separate scenarios for Customer owned assets. In the first one the customer owns and uses assets (servers, laptops, etc.) that are part of the solution. In this scenario, no testing is required. In the second scenario, the customer owns the assets; however, IBM is using them to perform the services as required. In this case, the following should be reviewed:

1. Was there a hardware inventory identified in the contract, or another official document, which is signed between IBM and the client? Was there evidence of customer agreement with the inventory?
2. Were both IBM and customer asset management obligations under the terms and conditions of the contract clearly defined? Was the customer agreement obtained and properly documented?
3. At contract initiation, was an initial inventory taken of all contracted assets? Was it properly identified in the applicable contract section? Was customer agreement obtained and documented? In absence of it, was a substitute procedure followed and documented?
4. Was there an adequate monitoring in place to identify the users and location of the customer owned assets?
5. Did IBM acknowledge the physical receipt of any client owned assets (hard copy signature, email), which were not received at the contract initiation, but the new assets used by IBM during the contract term?
6. Were the results of the asset sampling reviews communicated to the client in accordance with contract requirements or at least on annual basis (if there is no requirements in the contract)?

Customer Owned Software

1. Validate that all consents have been obtained for customer owned assets and software. If consents are identified to be the responsibility of the customer, review the contract for indemnification of responsibility to IBM.
2. Verify that there are controls in place to adequately monitor customer software being utilized by IBM in support of the contracted services.
3. Verify that IBM get assurance of customer's assets reception, not only the assets received at the contract initiation, but the new assets used by IBM during the contract term.

SERVICE DELIVERY EXTERNAL – BPO-D

AUDIT PROGRAM #62-20-00

BACKUP – Historical risk definition

(For retention purposes only {2018})

Process	Description of Risk
Contract requirements To ensure that delivered services are described and included in complete and approved.	Failure to properly control the delivery of contracted services could result in financial losses, and also negatively impact IBM's image.
Workforce management To ensure that appropriate resources are in place to deliver the contracted services for a customer. To ensure that resources are trained as needed, and that separated/leaving employees are promptly deleted from records and accesses.	Not having the right resources could impact in service delivery quality, not achieving contract SLAs, and could result in customer dissatisfaction and contract termination. Unskilled personal could compromise service delivery target attainments.
Labor claiming To ensure that employees claimed their hours accurately, completed and timely and that it has been recorded in accordance to IBM policies and aligned with country labor laws.	Noncompliance with labor regulations could compromise IBM ability to perform business and impact our image. It could also result in financial exposures.
Vendor management Are controls in place to ensure that contracted services are performed as required and deviation are promptly and effectively communicated to Procurement?	Vendor performance if not identify and reported to Procurement could compromise customer dissatisfaction and financial losses could occur.
Financial Controls To ensure that controls are in place to ensure that services are delivered in accordance to budget provisions, and aligned with guidelines.	Failure to comply with financial controls could result in financial losses, improper expenses, and could also impair the ability to achieve SLAs.
Matrix of Responsibilities (MoR) To ensure that the scope of work, contracts performance measurements and # of FTEs are approved and it is properly reflecting what is in the contract or an addendum.	Incorrect or untimely definition of BPO-D responsibilities could compromise all business targets and could lead to work at risk.
Contract Performance Measurements To ensure that conditions of success, as specified in the contract with the customer, are met	Not achieving contract targets could result in penalties on IBM, negatively impact the image, and contract termination.
System, application, and data access To ensure that access to the systems used to deliver services is controlled in a timely manner, and to prevent unauthorized access to applications and information used in the process.	Inadequate accesses could lead to unauthorized transactions, data privacy issues could result in litigation and contract termination.
Separation of Duties Analysis To ensure that all employee's task and system accesses are reviewed, identified, and controlled in an appropriate manner to prevent unauthorized transactions from occurring or remain undetected.	Undetected conflicting activities could result in financial losses, negative impact delivery performance and also creates an environment in which fraud could occur.
Assets Management (HW & SW) To ensure that controls are in place to ensure that assets are used as intended, inventoried and promptly tracked and consent letters are in place for SWG.	An ineffective process to control and monitor assets used in the delivery process, both IBM's and customer's, HW and SW, could compromise the service delivery performance, and also result in financial losses and legal exposures
Disaster Recovery and Business Continuity To determine if process owners have developed, reviewed, tested and approved business continuity plans/disaster recovery plans to ensure services can continue to be provided as committed.	Ineffective operation of the management system could damage IBM's image in the marketplace.
Data Protection and Data Privacy Evaluate whether data, including personal information (PI) and sensitive personal information (SPI) is appropriately secured and protected.	Failure to protect PI and SPI could enable fraudulent activity, which could result in dissatisfied employees, damage to employees and to IBM's image, and expose IBM to risk of litigation.